Éléments pour le délégué à la protection des données — registre des traitements et analyse d'impact

Proposition à adapter par le délégué à la protection des données (DPO, référent RGPD) de l'établissement. Ce document ne constitue pas un avis juridique ; les rubriques marquées « à valider » relèvent de la décision du responsable de traitement.

1. Fiche du registre des traitements (proposition)

Rubrique	Contenu proposé
Nom du traitement	Suivi des mesures d'isolement et de contention en psychiatrie
Responsable de traitement	L'établissement, représenté par son directeur
Finalités	1. Suivre la durée des mesures d'isolement et de contention et leur cumul ; 2. Anticiper et tracer l'information et la saisine du juge des libertés et de la détention ; 3. Tracer l'information des tiers et les professionnels chargés de la surveillance ; 4. Tenir le registre prévu à l'article L. 3222-5-1 du code de la santé publique ; 5. Produire le rapport annuel et des statistiques anonymisées
Base légale (à valider)	Article 6.1.c du RGPD (obligation légale : registre et contrôle du juge, art. L. 3222-5-1 du code de la santé publique) et 6.1.e (mission d'intérêt public) ; données de santé : article 9.2.h (prise en charge sanitaire) et 9.2.i (intérêt public dans le domaine de la santé publique)
Personnes concernées	Patients hospitalisés en psychiatrie faisant l'objet d'une mesure ; tiers informés (qualité seulement) ; professionnels (utilisateurs, psychiatres décisionnaires, soignants chargés de la surveillance)
Données des patients	Identité (nom, prénom, IPP, date de naissance), service, mode d'hospitalisation et son historique, mesure de protection juridique (oui ou type), mesures (type, lieu, dates et heures, psychiatre), information des tiers (qualité du tiers, résultat), communications avec le juge des libertés et de la détention (JLD)
Données des professionnels	Nom, identifiant, rôles, services affectés ; horodatage et auteur de chaque saisie
Destinataires	Agents habilités des unités concernées, selon leur rôle et leurs services ; registre (IPP, âge, psychiatre, soignants) : instances prévues par la loi (commission départementale des soins psychiatriques ou CDSP, Contrôleur général des lieux de privation de liberté ou CGLPL, parlementaires) ; demandeurs au titre du code des relations entre le public et l'administration (CRPA, avis de la Commission d'accès aux documents administratifs ou CADA) : version occultée seulement ; JLD : décompte joint aux communications
Transferts hors UE	Aucun. Les données ne quittent pas l'infrastructure de l'établissement. Si l'application est servie par GitHub Pages, seul le code est fourni par ce service, sans aucune donnée
Sous-traitants	Aucun pour les données (pas d'hébergeur externe)

Rubrique	Contenu proposé
Durée de conservation (à valider)	À fixer par l'établissement, en cohérence avec les règles applicables au registre et au dossier médical. L'outil conserve tout l'historique (journal jamais modifié) ; la durée choisie se saisit dans *Administration → Registre et statistiques* et l'outil signale les patients dont la dernière mesure la dépasse, à traiter selon la procédure validée par le délégué à la protection des données. Archive d'une année close : registres et statistiques en CSV (téléchargement tracé), plus une copie du dossier
Mesures de sécurité	Chiffrement AES-256 côté poste, comptes nominatifs et rôles, services affectés par compte, verrouillage après inactivité, journal inaltérable et chaîné, droits NTFS sur le dossier, sauvegardes, absence de flux sortant (voir la fiche technique)
Droits des personnes	Accès : export de toutes les données d'un patient (onglet Patients → Mesures → *Exporter ses données*, cadre ou administrateur, tracé au journal ; les noms des professionnels n'y figurent pas). Rectification : corrections tracées. Opposition et effacement : limités par l'obligation légale de tenue du registre (à valider)

2. Analyse d'impact (AIPD)

La liste de la CNIL des traitements pour lesquels une analyse d'impact est requise comprend les « traitements de données de santé mis en œuvre par les établissements de santé [...] pour la prise en charge des personnes » (CNIL). Le traitement porte en outre sur des personnes vulnérables, souvent hospitalisées sans leur consentement. **Une analyse d'impact paraît donc requise.** Elle peut être conduite avec l'outil PIA (logiciel d'analyse d'impact) de la CNIL ; les éléments ci-dessous en préparent la partie « risques ».

Risques et mesures

Événement redouté	Sources possibles	Mesures existantes	Gravité / vraisemblance (à évaluer)
Accès illégitime aux données	Copie du dossier, poste laissé ouvert, agent hors de son périmètre	Chiffrement ; mots de passe ou clés matérielles ; verrouillage automatique ; services affectés par compte ; journal des saisies limité selon le rôle (par défaut, IDE, AS et secrétaire ne voient que les saisies de leurs services) ; rôle « registre seulement » pour les personnes qui n'ont besoin que du registre (patients désignés par leur identifiant et leur âge, sans nom). Ces restrictions portent sur l'affichage : un compte ouvre la clé des données comme les autres, l'outil ne lui montre que ce que son rôle permet ; droits NTFS ; journal nominatif	
Modification non désirée	Erreur de saisie, saisies concurrentes, manipulation	Journal en ajout seul ; corrections et annulations tracées avec motif ; détection des conflits ; chiffrement authentifié (un fichier modifié est rejeté)	

Événement redouté	Sources possibles	Mesures existantes	Gravité / vraisemblance (à évaluer)
Exports en clair (PDF, CSV)	Décomptes et registres nominatifs copiés hors du réseau (téléchargements, clé USB, messagerie)	Enregistrement automatique dans le dossier des exports du partage (mêmes droits que les données), tracé au journal ; téléchargement seulement en secours ou à la demande ; durée de conservation réglable (purge automatique quotidienne, tracée) et suppression manuelle tracée par l'administrateur	
Disparition des données	Suppression de fichiers, panne, rançongiciel, coffre abîmé, perte des moyens de déverrouillage	Sauvegardes du partage (quotidiennes, 30 jours, copie hors ligne) ; historique vérifié du coffre (30 versions) ; copie du coffre sous scellé avec le code de secours ; copie de sauvegarde complète chiffrée sur un autre support, avec rappel ; contrôle d'intégrité (repères des agents, fichiers disparus ou illisibles, chaînage) à la connexion et toutes les 15 minutes, avec détail des fichiers pour le service informatique (DSI ou direction du numérique, selon l'établissement), réparation depuis une copie (fichiers absents ou illisibles seulement), quarantaine des fichiers illisibles et prise d'acte motivée et tracée des pertes définitives ; deux clés d'administration ; procédure dégradée papier	

Points d'attention pour l'analyse

- Le contrôle des rôles est réalisé par l'application sur le poste, sans serveur : un utilisateur disposant d'un compte valide et de compétences techniques pourrait le contourner, sans pouvoir effacer la trace de ses saisies.
- La perte simultanée de tous les moyens de déverrouillage rend les données irrécupérables : c'est la contrepartie d'un chiffrement effectif.
- Le registre légal désigne le patient par son IPP et son âge, comme l'exige l'article L. 3222-5-1, et mentionne le psychiatre et les soignants : il n'est présenté qu'aux instances prévues par la loi. Les exports statistiques ne contiennent ni nom ni IPP (pseudonymes P001, P002…).
- Pour une demande de communication d'un tiers (CADA), l'outil produit une **version occultée** du registre : identifiant patient occulté ou remplacé par un numéro propre au document, âge réduit (mineur / majeur, tranche) ou occulté, dates sans heure ou au mois, psychiatres et soignants occultés ou remplacés par des mentions génériques (Psychiatre 1, IDE 1, fonction et nombre), lieu et mode d'hospitalisation réductibles. Les choix les plus protecteurs sont présélectionnés, conformément à la décision du Conseil d'État du 8 février 2023 (n° 455887) ; chaque édition est tracée dans le journal avec les occultations appliquées et la référence de la demande. La version communiquée reste à valider par la direction ou le service juridique.
- Les impressions (décompte JLD, registre) sont des documents à protéger comme le dossier patient.
- **Copies des données hors du partage principal** (facultatives, décision de l'établissement) : dossier de secours sur un second serveur, et copie locale sur le disque de postes désignés pour le travail hors réseau (document 10). Ces copies restent chiffrées (même clé, mêmes mots de passe) ; une copie locale emporte toutefois les données chiffrées si le poste est volé : disque chiffré

(BitLocker), liste nominative des postes, suppression de la copie à la réforme du poste. Les exports en clair n'y sont jamais copiés.

3. Mode formation

Le jeu de formation ne contient que des données fictives générées par l'application (noms marqués « fictif »). Il est chiffré séparément et rangé dans le même dossier que les données réelles. La consigne de ne jamais y saisir de donnée réelle figure dans le bandeau affiché en permanence et dans les procédures ; l'administrateur peut régénérer le jeu à tout moment, ce qui efface son contenu, et retirer l'accès au mode formation compte par compte.

4. Information des personnes

Les patients sont informés par les moyens habituels de l'établissement (livret d'accueil, affichage, politique de confidentialité), en mentionnant ce traitement, ses finalités et les modalités d'exercice des droits.

Sources : CNIL, liste des types d'opérations de traitement pour lesquelles une AIPD est requise ; article L. 3222-5-1 du code de la santé publique ; Agence du numérique en santé (ANS), champ d'application de l'hébergement de données de santé ; MACSF, registre et occultation du nom du psychiatre.